Relazione DVWA – Burp Suite (S3L3)

Obiettivo

L'obiettivo dell'esercizio è stato analizzare il funzionamento del login della web application DVWA (Damn Vulnerable Web Application) utilizzando Burp Suite, intercettando e modificando le richieste HTTP.

Ambiente utilizzato

- Sistema operativo: Kali Linux (VirtualBox)
- Web server: Apache
- Database: MariaDB
- Applicazione: DVWA
- Tool: Burp Suite Community Edition
- Browser: Burp Browser / Firefox

Attività svolte

1. Avvio dei servizi

Sono stati avviati i servizi necessari:

- Apache
- MariaDB

Accesso alla web app tramite:
http://127.0.0.1/DVWA

2. Configurazione di Burp Suite

- Avvio di Burp Suite
- Creazione di un progetto temporaneo
- Verifica del proxy:
  - 127.0.0.1:8080
- Configurazione del browser per utilizzare il proxy

3. Intercettazione della richiesta

- Attivazione di **Intercept ON**
- Accesso alla pagina di login:

http://127.0.0.1/DVWA/login.php

- Inserimento credenziali (es. admin / password oppure errate)
- Intercettazione della richiesta POST in Burp

4. Analisi della richiesta HTTP

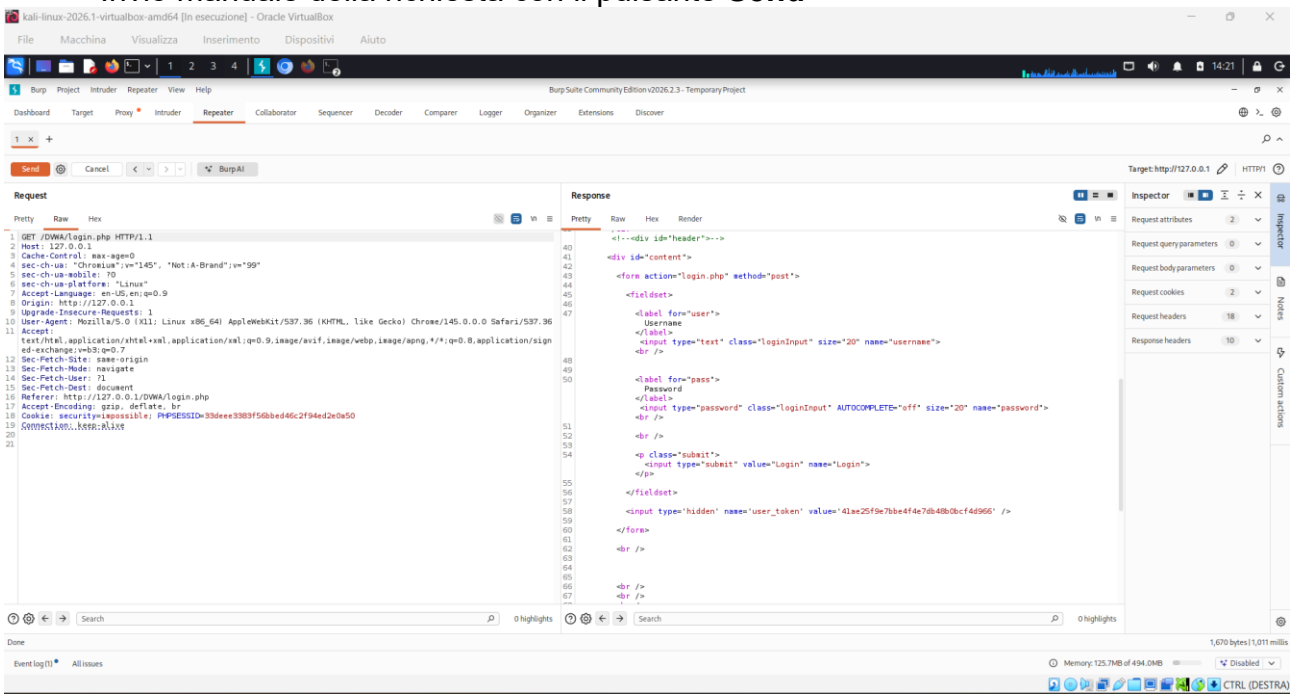
Richiesta intercettata:
POST /DVWA/login.php HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Parametri principali:
username=admin
password=password
Login=Login
user_token=...
Sono stati analizzati:

- Metodo HTTP (POST)
- Endpoint (/DVWA/login.php)
- Parametri di login
- Cookie di sessione (PHPSESSID)

- Token CSRF (user_token)

5. Invio al Repeater

- Click destro sulla richiesta → **Send to Repeater**
- Apertura della scheda **Repeater**
- Invio manuale della richiesta con il pulsante **Send**



6. Analisi della risposta

Risposta ottenuta:
HTTP/1.1 302 Found
Oppure, in caso di errore:

- Presenza del messaggio **"Login failed"** nel body HTML

Questo conferma che:

- Le credenziali errate non permettono l'accesso
- Il server gestisce correttamente l'autenticazione

Conclusioni

L'esercizio ha permesso di:

- Comprendere il funzionamento del proxy Burp Suite
- Intercettare richieste HTTP in tempo reale
- Analizzare parametri sensibili (username, password, token)
- Manipolare richieste prima dell'invio al server
- Utilizzare il modulo Repeater per test manuali

L'attività dimostra come sia possibile ispezionare e modificare il traffico web, competenza fondamentale nel penetration testing.